Team :skullpray:

Dakota State University

(Team 39)

White Team Documentation

Table of Contents

Public Services

Network Architecture

- Network Diagram
- WAN Rules
- LAN Rules
- MGMT Rules

Servers

- AD (Domain Controller)
- TICKETS (Ticketing Application)
- MGMT (Backend and Database)
- ADMIN (Transit Administration App)
- WWW (Public Website)

Backup Solutions

- Windows
- Linux

White Team Documentation

Public Services

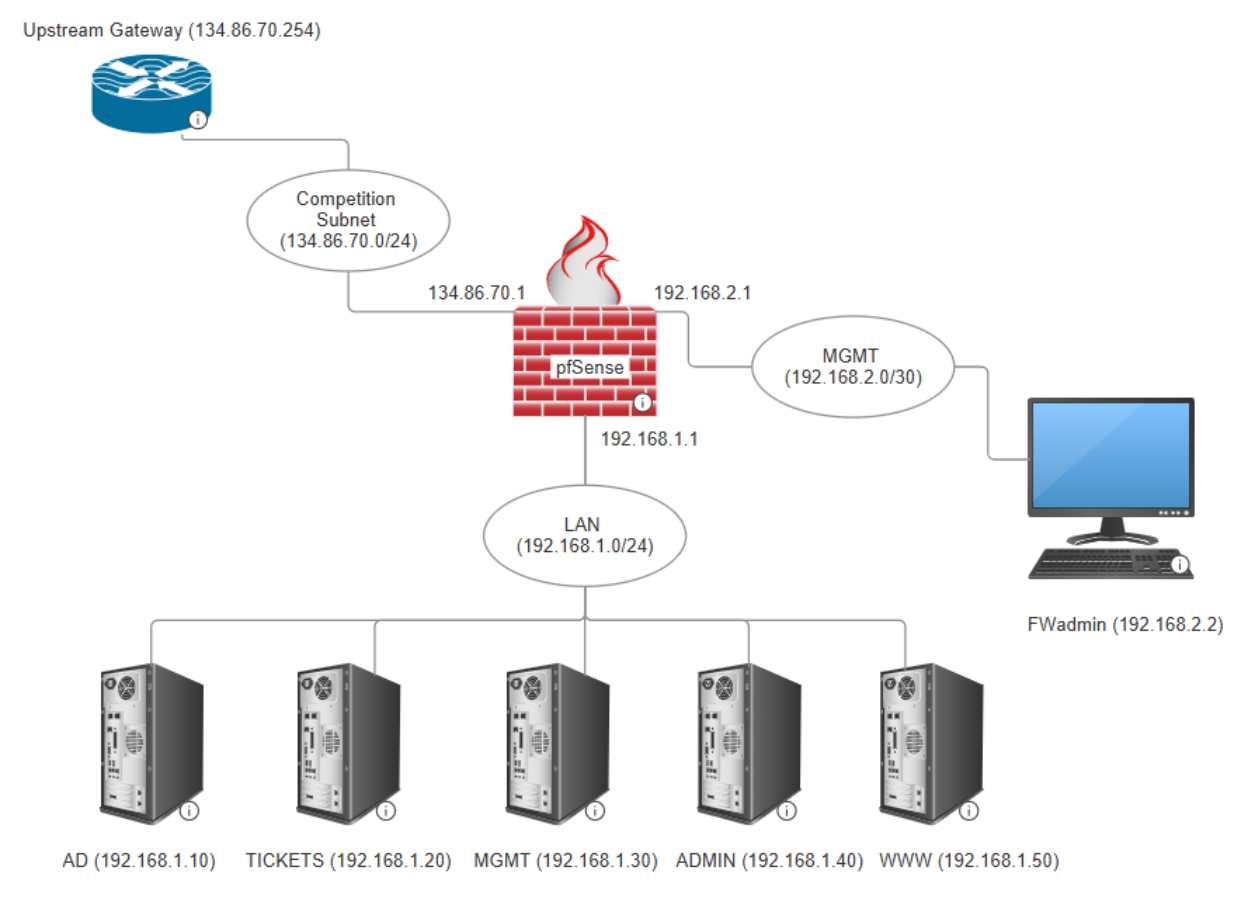
We have made the following services available from the competition network in order to meet the scoring and access requirements.

Domain Name	External IP	Ports
ad.team39.isucdc.com	134.86.70.10	389 (LDAP), 636 (LDAPS), 3389 (RDP)
tickets.team39.isucdc.com	134.86.70.20	5000 (HTTP), 3389 (RDP)
mgmt.team39.isucdc.com	134.86.70.30	5000 (HTTP), 22 (SSH)
admin.team39.isucdc.com	134.86.70.40	80 (HTTP), 3389 (RDP)
www.team39.isucdc.com	134.86.70.50	80 (HTTP), 22 (SSH)

Network Architecture

In order to control traffic between our servers and the WAN, we elected to insert a pfSense firewall on the competition network, placing our internal servers behind it on one of our local networks. We have implemented 1:1 inbound NAT and virtual IPs (proxy ARP) on pfSense in order to allow external use of our scored services. Outbound interface NAT was implemented in order to allow internal servers to reach the internet to meet the scenario requirements and to meet needs such as downloading packages. A new windows machine was placed onto a separate, segmented internal network in order to manage the firewall without needing to expose it or the firewall to either the competition network or even the LAN.

Network Diagram



The internal network is behind 1:1 NAT, which allows pfSense to implement strict security policies regarding both what is allowed in and out of our internal network, reducing the attack surface significantly. All 5 internal servers were placed on the same subnet, meaning pfSense does not have control over traffic between internal machines. We utilize strict host-based firewalls, including iptables and Windows firewall, to allow both in and out only traffic that is necessary, with all default policies set to deny. This creates multiple layers of firewall protection, giving excellent redundancy. The stateful inspection offered by pfSense allows us to add rules to each interface only for the traffic we expect to be initiated inbound on that interface.

WAN Rules

Rules on the WAN interface of pfSense control traffic that comes from the competition network and is destined for our internal LAN. Based on the internal IPs of our servers and the specific ports that their scored services are accessible on (which can be accessed earlier in this document), we created rules to minimize the attack surface as much as possible. Only scored

ports are allowed inbound to their respective scored machines, and all other traffic is dropped. This covers all requirements necessary in order for our services to function. 1:1 NAT using /24 subnets is performed on traffic destined to our internal servers' public IPs; for example, 134.86.70.10 would be translated to 192.168.1.10. NAT entries exist for only our five internal servers, while no NAT entry exists for the FWadmin machine, making it unreachable from the competition network. No traffic is allowed to pfSense itself, making it invisible from the competition network.

LAN Rules

Rules on the LAN interface control traffic that is initiated outbound from our internal servers to the internet. Because pfSense is stateful, this does not need to cover any return traffic for requests to internal services. In order to maintain the internet access requirement for our internal machines, a single rule is applied on this interface to allow traffic outbound to the proxy. No other traffic is allowed, which is best practice for maintaining internet access through the proxy while working to block any potential exfiltration or callbacks in the event of an internal compromise. Due to the existence of the MGMT subnet for accessing the pfSense GUI, no traffic is allowed to pfSense on this interface either, making it invisible from the LAN other than as a gateway.

MGMT Rules

Rules on the MGMT interface control traffic that is initiated outbound from the FWadmin machine. The main function of this interface is to allow administration of pfSense from this subnet, which is performed via an allow rule for HTTPS on pfSense. No NAT rule on the WAN interface exists to allow traffic into this subnet, creating us a setup in which we can manage the firewall risk-free from the FWadmin machine while keeping both it and the firewall itself entirely invisible from the perspective of both the LAN and the competition subnet. This practice reduces our risk of a compromised firewall as much as possible, giving us a fortified subnet from which to control north-south traffic while remaining invisible. A single other rule allows traffic out to the internet through the proxy, allowing our firewall admin to download packages such as Wireshark for use in threat hunting.

Servers

AD (Domain Controller)

This machine is the domain controller of our Active Directory domain, to which all other internal machines are joined. It is used for services such as DNS and to manage domain users and services.

Details:

OS: Windows Server 2016

FQDN: ad.team39.isucdc.com

Internal IP: 192.168.1.10

Public IP: 134.86.70.10

Service ports: 389 (LDAP), 636 (LDAPS), 3389 (RDP)

Firewall Rules:

The host Windows firewall has been configured with a default policy of drop. Traffic is allowed inbound to ports necessary for Active Directory. Traffic is allowed outbound to the proxy and the time server.

Security Fixes:

Users and permissions were severely misconfigured throughout the domain.

- Normal users are no longer members of the domain admins group and have correct permissions.
- Only IT administrators are allowed to open an RDP session on this machine.
- Anonymous enumeration of the LDAP directory has been disabled.
- Domain users have been assigned to the correct Active Directory groups, giving each user the appropriate level of permissions on each machine within the domain.

TICKETS (Ticketing Application)

This machine houses the ticketing application used to sign and validate bus and train tickets used by citizens.

Details:

OS: Windows Server 2019

FQDN: tickets.team39.isucdc.com

Internal IP: 192.168.1.20

Public IP: 134.86.70.20

Service ports: 5000 (HTTP), 3389 (RDP)

Firewall Rules:

The host Windows firewall has been configured with a default policy of drop. Traffic is allowed inbound to ports 3389 and 5000 for scored services, as well as from the domain controller for Active Directory communication. Traffic is allowed outbound to the proxy and the domain controller.

Security Fixes:

Some minor security changes were made to secure the system.

- Malware was removed from a startup task location.
- Unauthorized users were removed, and only IT Administrators and Ticket Maintenance are permitted to open an RDP session.

Tickets Application Fixes:

The ticketing application contained issues that allowed for forgery of tickets.

- An API endpoint that exposed the server private signing key was removed.
- Tickets are now required to be validated against the server's official certificate.
- The app no longer runs in development mode.

MGMT (Backend and Database)

This server houses the backend API that is used by both web applications for authentication, as well as the database that stores customer ticket and payment information. Bus and Train data, including routes, is also stored here.

Details:

OS: Alma Linux 8.4

FQDN: mgmt.team39.isucdc.com

Internal IP: 192.168.1.30

Public IP: 134.86.70.30

Service ports: 5000 (HTTP), 22 (SSH)

Firewall Rules:

The host firewall was configured using iptables with a default policy of drop. Traffic is allowed inbound to ports 5000 and 22 for scored services. Traffic is allowed outbound to the proxy, to the ticketing application on the MGMT machine, and to specific ports on the domain controller. Traffic on localhost, as well as established and related traffic, are permitted as well.

Security Fixes:

Security issues mostly having to do with users and permissions were discovered.

- User permissions have been restricted to least privilege, allowing administrative and remote access only to the IT Administrators group.
- Privilege escalation avenues on an older operating system version were mitigated.
- Fail2ban was added for the SSH service to prevent brute forcing.
- The machine only listens for remote connections on scored ports, with applications such as MariaDB now listening only on localhost and being secured.

Backend Application Fixes:

The custom backend application was found to have several severe vulnerabilities that allowed instant domain compromise.

- Password authentication is now enforced and users are provided the proper permissions.
- Sessions are correctly configured with secure secrets to prevent session stealing or forgery.
- The app no longer runs in debug mode.
- Newly added users are no longer added to the Transit Admins group and instead are regular users.
- LDAP injection was prevented with the use of escape_filter_chars() and escape_rdn() functions.
- The app now runs as an unprivileged service user and has correct permissions on the source code files.

ADMIN (Transit Administration App)

This machine contains the Transit Administration web application that is used by Transit Admins to manage the city's fleet of buses and trains.

Details:

OS: Windows Server 2022

FQDN: admin.team39.isucdc.com

Internal IP: 192.168.1.40

Public IP: 134.86.70.40

Service ports: 80 (HTTP), 3389 (RDP)

Firewall Rules:

The host Windows firewall has been configured with a default policy of drop. Traffic is allowed inbound to ports 3389 and 80 for scored services, as well as from the domain controller for Active Directory communication. Traffic is allowed outbound to the MGMT backend, the proxy, and the domain controller.

Security Fixes:

Security issues mostly having to do with user accounts and permissions were discovered.

- Unauthorized users have been disabled, and only IT Administrators are permitted to open an RDP session on this server.
- Legacy insecure services such as SMBv1 have been disabled.

Web Application Fixes:

The web application had severe vulnerabilities that allowed anyone to access the admin web application.

- Only Transit Admins are now allowed to use the web application.
- The app no longer runs in debug mode.
- Sessions are now managed properly to prevent session stealing and forgery.
- XSS attacks have been mitigated by preventing JavaScript from accessing session cookies.

WWW (Public Website)

This machine hosts the public website for the transit system, where citizens can sign up, configure their payment information, and purchase and scan their transit tickets.

Details:

OS: Alma Linux 9.7

FQDN: www.team39.isucdc.com

Internal IP: 192.168.1.50

Public IP: 134.86.70.50

Scored ports: 80 (HTTP), 22 (SSH)

Firewall Rules:

The host firewall was configured using iptables with a default policy of drop. Traffic is allowed inbound to ports 80 and 22 for scored services. Traffic is allowed outbound to the proxy, to the backend application on the MGMT machine, and to specific ports on the domain controller. Traffic on localhost, as well as established and related traffic, are permitted as well.

Security Fixes:

Several backdoors and instances of malware were found on this machine, and user permissions were highly misconfigured.

- Unauthorized accounts were removed from the system and remote access, as well as administrative control, is provided only to members of the IT Administrators group.
- Backdoored services, SUID binaries, and LD_PRELOAD malware were identified and removed from the system.
- Only the required service ports are listening for remote connections.
- Fail2ban has been set up for both SSH and the public website login API endpoint to prevent brute force attacks.

Web Application Fixes:

The frontend web application had multiple security issues.

- Sessions are now managed properly with individual sessions and secure authentication cookies.
- The app is now run by a service user without interactive logon and has proper permissions.
- The app is no longer run in debug mode.
- XSS attacks have been mitigated by preventing JavaScript from accessing session cookies.

Backup Solutions

In order to meet the requirement of backing up core parts of each of our systems, scheduled backups were added to each of our servers.

Windows

For Windows servers, the wbadmin.exe application was used to schedule a system backup every 30 minutes. This is an efficient, built-in solution that allows us to add some redundancy to our Windows systems.

Linux

For Linux servers, a mixed solution was used to back up all required data. To back up critical directories on the system, cronjobs were used in conjunction with a git repository in order to track changes. Due to Git's use of deltas to track changes, this is a low-storage solution. To backup databases, the mysqldump tool was used in conjunction with a cronjob that compresses the backups and rotates them every 2 cycles, ensuring that no more than 2 backed up version are kept for storage efficiency. Both of these solutions run every 30 minutes.